GitHub

88 Colin P Kelly Jr Street,
San Francisco, CA 94107
Tel: 415-448-6673 (main)

GitHub Bug Bounty Detailed Letter of Engagement: Jan – Mar 2025

GitHub has a mature and well-established bug bounty program that has been actively expanded since the program began in 2014. Through this bounty program, GitHub works with security researchers to continually assess and harden GitHub's services and products. The purpose of this continual security researcher engagement is to find and fix security issues that may expose the platform or the security of our customers. This program works in conjunction with the internal processes and team functions that actively test our products and features.

GitHub hosts the bug bounty program on HackerOne, engaging with the global hacker community to surface relevant product security issues. More information about HackerOne's processes and products can be found at https://www.hackerone.com/trust.

Overview

A traditional penetration test provides a 'point-in-time' evaluation of GitHub's security posture, whereas a bug bounty program continuously assesses our security posture and ever-evolving product features. This fundamental difference between the two approaches enables us to move security testing from a compliance exercise to a true, ongoing verification of our security posture. It takes into account that security threats and adversarial techniques are continually evolving and so must the defenses that GitHub deploys. In addition, employing an ongoing bug bounty program allows us to test new GitHub features as soon as they are completed and made available rather than waiting for a regularly scheduled penetration test engagement.

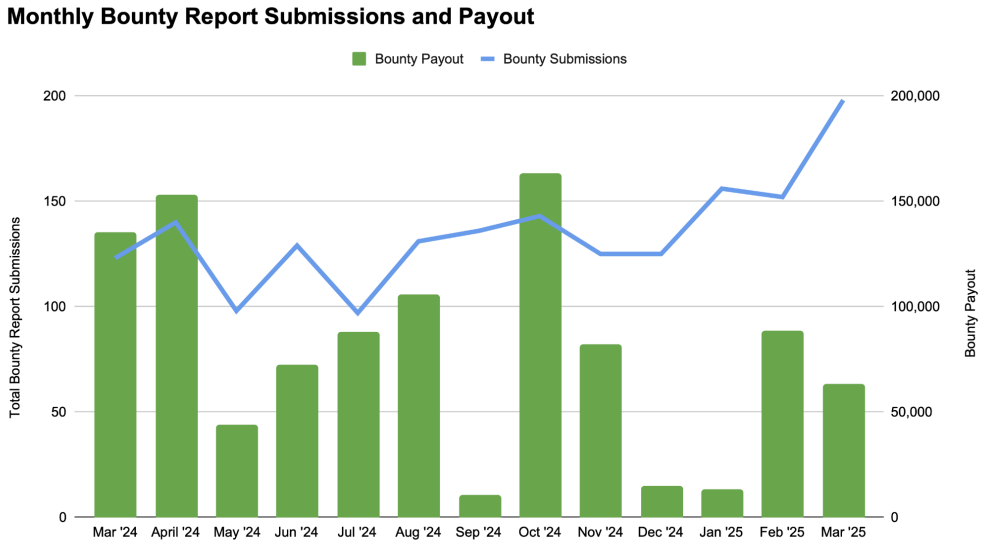
Our bug bounty program leverages the external security community on the HackerOne platform to assess the full breadth of GitHub's products, services, and infrastructure, including GitHub.com, GitHub Enterprise Server, GitHub Enterprise Cloud platforms, GitHub Actions, GitHub Pages, GitHub Advanced Security, the GitHub API, Codespaces, GitHub Copilot, and the npm ecosystem. This broad scope is combined with the expertise, creativity, and focus of security researchers to provide a level of depth that a penetration test cannot provide on a platform as large and complicated as GitHub. As we release new features and increase our digital footprint, we continue to see increasing value in our bug bounty program.

The rules for testing are simple and are covered in the Rules of Engagement, which include the following limitations:

- Do not perform content spamming.
- Do not perform volumetric (i.e., denial of service) attacks, unless researching against your own instance of GitHub Enterprise Server.
- On GitHub.com, perform research only on your own repositories and desist if you believe you have affected the availability of GitHub's services.
- Do not intentionally access Personally Identifiable Information (PII) that is not your own.

These guidelines minimize PII exposure and customer impact from security research and testing.

As our features and product scope have expanded over the years, our bounty scope has continued to expand to match this increase in our security surface area. Due to this continual expansion, interest and engagement in our bounty program has also continued to increase over the years, leading to consistent growth in the number of bounty reports submitted to our program. From Mar 2024 to Mar 2025, our average monthly bounty submission rose from 130 reports to 135 monthly submissions, as shown in the graph below.



Summary of Findings

During the period of Jan 1, 2025, to Mar 31, 2025, the program identified:

- 1 (one) critical severity vulnerability
- 3 (three) high severity vulnerabilities
- 10 (ten) medium severity vulnerabilities
- 23 (twenty three) low severity vulnerabilities
- 18 (eighteen) defense-in-depth vulnerabilities

Bounty Reports by Severity	
Critical	1
High	3
Medium	10
Low	23
Defense-in-depth	18

GitHub has remediated all critical and high severity findings as part of the standard operating procedures of the bug bounty program. To date, we have remediated 80% of the medium severity findings and over 91% of the low severity findings, and we are on track for resolving all findings via GitHub's Bug Bounty Workflow based on our severity guidelines.

Remediated Bounty Reports by Severity		
Critical	Remediated	1
	Not Yet Remediated	0
High	Remediated	3
	Not Yet Remediated	0
Medium	Remediated	8
	Not Yet Remediated	2
Low	Remediated	21
	Not Yet Remediated	2
Defense-in-Depth	Remediated	10
	Not Yet Remediated	8

Defense-in-depth severity issues are areas that have been identified where we could improve our resilience to security vulnerabilities and their exploitation. Examples of defense-in-depth issues include adding a Content Security Policy to an application in case there is a gap in output encoding from untrusted input, implementing additional process isolation for services to limit the impact of the exploitation of a service, and documentation changes to ensure that our customers understand the intended functionality of features. Because these issues are not directly exploitable but rather improve our overall security posture, our workflow allows more time to implement these improvements.

We will continue to evolve this report to provide customers with more transparency around GitHub's security posture and our continual efforts to ensure the trust you have in us is earned.

Best regards,
GitHub Security